Contents

Volume 05 — System Attacks & Hardware Security (L41–L50) **1**
L41: Password Cracking . . . 1
L42: Phishing Attack . . . 2
L43: Malware . . . 2
L44: Wi-Fi Hacking . . . 3
L45: DoS and DDoS Attack . . . 4
L46: Elements of Hardware Security . . . 4
L47: Side Channel Attacks — Part I . . . 5
L48: Side Channel Attacks — Part II . . . 5
L49: Physical Unclonable Function . . . 6
L50: Hardware Trojan . . . 7

Volume 05 — System Attacks & Hardware Security (L41–L50)

> Ethical Hacking · NPTEL 106105217 · Prof. Indranil Sengupta
> **notes-3** — concept exam notes (what things are / what they do). No lab command dumps.

Passwords, phishing, malware, Wi-Fi, DoS, side channels, PUF, hardware trojans.

L41: Password Cracking

What it is / what it does

- **Password storage:** never plaintext; hash with salt + slow algorithm (bcrypt, Argon2).
- **Windows hashes:** LM (obsolete, case-insensitive, 7-char chunks) and NTLM (MD4 of UTF-16LE password).
- **Linux hashes:** MD5 (1), SHA-256 (5), SHA-512 (6), bcrypt ($2a$), yescrypt.
- **Attack types:** dictionary, brute-force, hybrid, rule-based, rainbow tables.
- **Pass-the-hash:** authenticate using NTLM hash without cracking plaintext.

Defenses (one-liners)

- Password policy: length ≥ 12, complexity, no common passwords
- MFA on all accounts
- Account lockout / rate limiting
- Use Argon2id/bcrypt for application password storage

Exam lines

- NTLM hash = **MD4** of password; Hashcat mode **1000**.
- Dictionary attack tries **wordlist entries**; brute-force tries all combinations.
- Rainbow tables are precomputed — defeated by **salting**.
- Pass-the-hash uses **NTLM hash directly** without cracking plaintext.

- LM hash splits password into **7-character chunks** (case-insensitive).

L42: Phishing Attack

What it is / what it does

- **Phishing types:** mass phishing, spear phishing (targeted), whaling (executives), vishing (voice), smishing (SMS).
- **Attack chain:** recon → craft lure → deliver payload → capture credentials → establish access.
- **Indicators:** mismatched URLs, urgency language, generic greetings, suspicious attachments.
- **Clone phishing:** copy legitimate email, replace links/attachments with malicious versions.
- **Business Email Compromise (BEC):** impersonate executive to authorize wire transfers.

Defenses (one-liners)

- Security awareness training with simulated phishing
- SPF + DKIM + DMARC (p=reject)
- Email gateway filtering and link sandboxing
- MFA (hardware tokens resist Evilginx2 better than SMS)

Exam lines

- Spear phishing targets **specific individuals** with personalized content.
- Clone phishing **replicates legitimate emails** with malicious modifications.
- Evilginx2 performs **AiTM (adversary-in-the-middle)** to steal session cookies.
- DMARC p=reject blocks emails failing **SPF and DKIM** checks.
- Whaling targets **C-level executives** (high-value targets).

L43: Malware

What it is / what it does

- **Malware categories:** virus (needs host), worm (self-replicating), trojan (disguised), ransomware, spyware, rootkit, adware.
- **Propagation:** email attachments, drive-by download, USB, exploit kits, lateral movement.
- **Persistence mechanisms:** registry Run keys, scheduled tasks, services, DLL hijacking, firmware.
- **Anti-analysis:** packing, obfuscation, VM/sandbox detection, encrypted strings.
- **RAT (Remote Access Trojan):** provides attacker remote control (DarkComet, njRAT, Cobalt Strike).

Defenses (one-liners)

- Endpoint Detection and Response (EDR)
- Application whitelisting
- Disable macros by default in Office
- Network monitoring for C2 beacon patterns

Exam lines

- Virus requires **host program**; worm spreads **autonomously**.
- Trojan **disguises** as legitimate software (user-initiated execution).
- Rootkit operates at **kernel/firmware level** — hides from OS.
- Packing/obfuscation defeats **signature-based** AV detection.
- RAT provides **remote access and control** over infected system.

L44: Wi-Fi Hacking

What it is / what it does

- **802.11 standards:** a (5 GHz), b/g (2.4 GHz), n (MIMO), ac/ax (Wi-Fi 5/6).
- **Authentication:** Open, WEP (broken), WPA (TKIP, deprecated), WPA2 (AES-CCMP), WPA3 (SAE).
- **4-way handshake:** AP ↔ client key exchange; captures used for offline cracking.
- **Monitor mode:** NIC captures all wireless frames (not just associated BSS).
- **Deauthentication attack:** forged deauth frames disconnect clients (capture handshake on reconnect).

Defenses (one-liners)

- WPA3 with SAE (resistant to offline dictionary attacks)
- Strong passphrase (≥ 15 random characters)
- 802.11w (protected management frames) prevents deauth attacks
- Enterprise WPA2-Enterprise (802.1X/RADIUS) — per-user credentials

Exam lines

- WEP uses **RC4** — cracked in minutes; never use.
- WPA2-PSK crack requires capturing **4-way handshake** or PMKID.
- Deauth attack sends forged **deauthentication frames** to disconnect clients.
- Monitor mode captures **all wireless traffic** on channel (promiscuous for Wi-Fi).
- WPA3 SAE replaces PSK with **dragonfly key exchange** (anti offline-dict).

L45: DoS and DDoS Attack

What it is / what it does

- **DoS:** single source overwhelms target; **DDoS:** distributed attack from botnet (zombies).
- **Attack types:**
- Volume-based: UDP flood, ICMP flood, DNS amplification
- Protocol-based: SYN flood, Ping of Death
- Application-layer: HTTP flood, Slowloris, RUDY
- **Amplification:** small query → large response (DNS, NTP, memcached reflection).
- **Botnet:** network of compromised machines (Mirai, Emotet) controlled by C2 server.

Defenses (one-liners)

- SYN cookies (kernel-level SYN flood mitigation)
- Rate limiting and traffic shaping
- CDN/DDoS scrubbing services (Cloudflare, Akamai)
- Anycast distribution to absorb volume

Exam lines

- SYN flood exploits **TCP 3-way handshake** — fills connection queue with half-open connections.
- DNS amplification achieves **bandwidth multiplication** (small query, large response).
- Slowloris is **application-layer** attack — holds connections with incomplete requests.
- Botnet = **network of compromised machines** controlled by attacker (C2).
- DDoS mitigation: **rate limiting + CDN scrubbing + SYN cookies**.

L46: Elements of Hardware Security

What it is / what it does

- **Hardware root of trust:** secure boot chain from immutable ROM (TPM, secure enclave).
- **TPM (Trusted Platform Module):** hardware chip storing keys, measurements, attestation.
- **Secure boot:** verify firmware/OS signatures before execution (UEFI Secure Boot).
- **Hardware Security Module (HSM):** dedicated crypto processor for key management.
- **TrustZone (ARM) / SGX (Intel):** isolated execution environments (TEE).

Defenses (one-liners)

- Enable UEFI Secure Boot with vendor + custom keys

- TPM-based disk encryption (BitLocker, LUKS with TPM binding)
- Disable JTAG/debug interfaces in production
- Physical tamper detection (enclosure switches, epoxy)

Exam lines

- TPM provides **hardware root of trust** for key storage and attestation.
- Secure Boot verifies **digital signatures** of firmware/OS before loading.
- HSM = dedicated hardware for **crypto key management** (high-security environments).
- TrustZone/SGX create **Trusted Execution Environments** isolated from main OS.
- Evil maid attack: physical access to **tamper with boot process**.

L47: Side Channel Attacks — Part I

What it is / what it does

- **Side-channel attack:** exploit physical implementation leakage, not algorithm weakness.
- **Power analysis:** measure power consumption during crypto operations.
- **SPA (Simple Power Analysis):** visual inspection of power traces.
- **DPA (Differential Power Analysis):** statistical correlation of traces with key bits.
- **Timing attack:** measure operation duration to infer secret data (Kocher 1996).
- **Electromagnetic (EM) leakage:** capture EM emissions from chip during computation.

Defenses (one-liners)

- **Masking:** randomize intermediate values in crypto operations
- **Constant-time implementations:** prevent timing variations
- **Power/EM shielding:** Faraday cage, filtering capacitors
- **Noise injection:** add random operations to obscure signal

Exam lines

- Side-channel attacks exploit **physical leakage** (power, timing, EM), not math weaknesses.
- DPA uses **statistical analysis** of many power traces to recover key bits.
- SPA requires **visual inspection** of single/few power traces.
- Timing attack: measure **operation duration** to infer secret (e.g., RSA key bits).
- Constant-time code prevents **timing side channels**.

L48: Side Channel Attacks — Part II

What it is / what it does

- **Cache timing attacks:** exploit CPU cache behavior (Flush+Reload, Prime+Probe).

- **Spectre/Meltdown:** CPU speculative execution leaks data across security boundaries.
- **Acoustic cryptanalysis:** recover RSA keys from coil whine (disk encryption).
- **Fault injection:** glitch voltage/clock/laser to cause computation errors → leak key material.
- **Rowhammer:** repeatedly access DRAM rows to flip bits in adjacent rows.

Defenses (one-liners)

- Microcode updates for Spectre/Meltdown mitigations
- Cache partitioning (CAT — Cache Allocation Technology)
- ECC memory against Rowhammer
- Double-and-add randomization in crypto implementations

Exam lines

- Meltdown breaks **user/kernel isolation** via speculative execution.
- Spectre tricks programs into **leaking data** via mispredicted branches.
- Rowhammer exploits **DRAM physical proximity** to flip bits without direct access.
- Fault injection (voltage/clock glitch) causes **computation errors** revealing key material.
- Flush+Reload is a **cache timing attack** on shared cache lines.

L49: Physical Unclonable Function

What it is / what it does

- **PUF (Physical Unclonable Function):** hardware instance-specific challenge-response based on manufacturing variations.
- **Types:** SRAM PUF (power-on state), ring oscillator PUF, arbiter PUF, optical PUF.
- **Properties:** uniqueness (different chips → different responses), reliability (same challenge → same response), unclonability.
- **Applications:** device authentication, key generation, anti-counterfeiting, secure boot binding.
- **FPGA/IC fingerprinting:** identify specific hardware instance without stored secret.

Defenses (one-liners)

- Helper data schemes (fuzzy extractors) for error correction without revealing PUF
- Limit exposed challenge-response pairs (prevent modeling)
- Combine PUF with secure enclave
- Environmental monitoring to detect tampering

Exam lines

- PUF exploits **manufacturing variations** for unique device identity.
- PUF response is **unclonable** — cannot replicate on different chip.

- SRAM PUF uses **power-on random state** of uninitialized SRAM.
- Modeling attack uses **ML on C-R pairs** to clone PUF behavior.
- PUF used for **device authentication** and **key derivation**.

L50: Hardware Trojan

What it is / what it does

- **Hardware Trojan:** malicious modification to IC/hardware at design, fabrication, or assembly stage.
- **Trojan types:** functional (change behavior) vs parametric (degrade performance); trigger: always-on, condition-based.
- **Insertion points:** RTL design, synthesis, placement, fabrication (untrusted foundry).
- **Payloads:** information leakage, denial of service, privilege escalation, kill switch.
- **Detection difficulty:** no equivalent of AV for hardware; golden chip comparison required.

Defenses (one-liners)

- Trusted foundry and supply chain verification
- Split manufacturing (no single entity has full design)
- Runtime monitoring for anomalous behavior
- Formal verification of RTL against golden reference

Exam lines

- Hardware Trojan inserted at **design, fabrication, or assembly** stage.
- Functional Trojan **changes circuit behavior**; parametric degrades performance.
- Trigger types: **always-on** or **condition-based** (rare input pattern).
- Untrusted foundry is primary threat in **offshore chip manufacturing**.
- Detection requires **golden chip comparison** or side-channel anomaly analysis.